UNIVERSIDADE MOGI DAS CRUZES
ENGENHARIA DE SOFTWARE

André Quintino Aires Afonso
Carlos Vinicius Borba Ribeiro
Kauet Yudi Sugawara Brito

ESTEIRA DEVSECOPS

OWASP ZAP, Bearer e Trivy aplicados ao projeto EmprestaCampus

Mogi das Cruzes
2026

André Quintino Aires Afonso
Carlos Vinicius Borba Ribeiro
Kauet Yudi Sugawara Brito

ESTEIRA DEVSECOPS

OWASP ZAP, Bearer e Trivy aplicados ao projeto EmprestaCampus

Relatório técnico do projeto EmprestaCampus apresentado ao curso de Engenharia de Software da Universidade Mogi das Cruzes, como requisito parcial de avaliação.

Mogi das Cruzes
2026

SUMÁRIO

1 INTRODUÇÃO À ARQUITETURA OPEN-SOURCE 3
1.1 Arquitetura da esteira 4
2 DESCRITIVO TÉCNICO DAS FERRAMENTAS 5
2.1 OWASP ZAP: testes com a aplicação em execução (DAST) 5
2.2 Bearer: privacidade e dados pessoais (SAST) 6
2.3 Trivy: inventário de componentes e SBOM 6
3 INTEGRAÇÃO COM OS REQUISITOS DO PROJETO 7
3.1 Validação de privacidade e a LGPD 7
3.2 SBOM e a conformidade do produto entregue 7
3.3 Limites da esteira 8
4 EVIDÊNCIAS DE FUNCIONAMENTO 8
4.1 Execução com os três jobs bem-sucedidos 8
4.2 Artefato SBOM gerado e disponível para download 9
5 CONCLUSÃO 10

1 INTRODUÇÃO À ARQUITETURA OPEN-SOURCE

Um nível profissional de segurança no ciclo de desenvolvimento (SecDevOps) não depende de licenças comerciais. O ecossistema comunitário oferece ferramentas maduras para cada camada de risco, e o GitHub Actions permite orquestrá-las em um único fluxo automatizado, executado a cada *push*, *pull request* ou sob demanda. A ideia central é o *shift-left*: encontrar falhas cedo, quando corrigi-las é mais barato, em vez de descobri-las em produção.

No EmprestaCampus, sistema web de empréstimo de equipamentos acadêmicos, a esteira cobre três perspectivas complementares de risco, cada uma com uma ferramenta gratuita:

a) aplicação em execução (DAST): o OWASP ZAP ataca a aplicação rodando e procura falhas exploráveis;
b) código-fonte e privacidade (SAST): o Bearer analisa o código e mapeia dados pessoais (PII);
c) cadeia de suprimentos: o Trivy gera o inventário de componentes (SBOM) da imagem Docker entregue.

A orquestração utiliza apenas GitHub Actions, Docker e Docker Compose. O próprio fluxo adota medidas de endurecimento: permissões mínimas (*contents: read*), *persist-credentials: false* na obtenção do código, ações fixadas por hash de *commit*, segredos efêmeros gerados a cada execução e verificação SHA-256 do binário do Trivy.

Quanto ao licenciamento, o OWASP ZAP e o Trivy são projetos de código aberto, e a *action* oficial do ZAP é distribuída sob Apache-2.0 (ZAP, [s.d.]). O Bearer CLI é gratuito e tem o código disponível, mas, segundo a documentação consultada, é distribuído sob a *Elastic License 2.0*, que não é uma licença aprovada pela *Open Source Initiative* (BEARER, [s.d.]). Por isso, o termo mais preciso para o conjunto é ferramentas gratuitas, de código aberto ou disponível.

1.1 Arquitetura da esteira

O fluxo de trabalho DevSecOps Avançado é acionado por *push* na ramificação principal, por *pull request* direcionado a ela ou manualmente, e executa três tarefas (*jobs*) em paralelo, conforme o Quadro 1.

Quadro 1 – Visão geral dos três jobs do fluxo DevSecOps Avançado

Gatilhos	Job 1: DAST	Job 2: Privacidade	Job 3: Supply Chain
push em main; *pull_request* para main; *workflow_dispatch*	**OWASP ZAP**: sobe PostgreSQL, Django e Nginx (HTTPS) e executa o *Full Scan*	**Bearer CLI**: analisa o código, bloqueia achados crítico, alto e médio e gera inventário de PII	**Trivy**: constrói a imagem do backend e gera o SBOM CycloneDX
Os três *jobs* rodam em paralelo	Artefato: *zap-full-scan-report*	Artefato: *bearer-relatorios*	Artefato: *sbom-cyclonedx*

Fonte: elaborado pelos autores a partir do arquivo de configuração do repositório (EMPRESTACAMPUS, 2026).

2 DESCRITIVO TÉCNICO DAS FERRAMENTAS

2.1 OWASP ZAP: testes com a aplicação em execução (DAST)

O ZAP (*Zed Attack Proxy*) é um scanner de segurança de aplicações web do projeto OWASP. Na modalidade *Full Scan*, a *action* oficial executa primeiro o *spider* contra o alvo, opcionalmente um *ajax spider*, e depois uma varredura ativa completa antes de reportar os resultados (ZAP, [s.d.]). Como realiza ataques reais, deve ser usado apenas em alvos autorizados, o que no projeto é garantido por rodar contra um ambiente descartável no próprio executor do GitHub.

No EmprestaCampus, a tarefa sobe a aplicação completa com *docker compose up --build -d* e a testa por HTTPS em *https://localhost/*, passando pelo Nginx exatamente como em produção. O ambiente usa *DEBUG=False*, de modo que cookies *Secure*, HSTS e redirecionamento HTTPS do Django estejam ativos durante o teste.

O arquivo *.zap/rules.tsv* define a política de bloqueio. Achados de injeção e execução de código (XSS, SQL *Injection*, injeção de comandos, SSTI, XXE, CRLF, *path traversal* e RFI) são classificados como FAIL e reprovam a tarefa. Achados de configuração de cabeçalhos e cookies são classificados como WARN e aparecem no

relatório sem bloquear. A opção *-l* impede que alertas de nível WARN reprovem a execução.

2.2 Bearer: privacidade e dados pessoais (SAST)

O Bearer CLI é uma ferramenta de análise estática (SAST) que examina o código-fonte e analisa fluxos de dados para identificar e priorizar riscos de segurança e de privacidade (BEARER, [s.d.]). Seu diferencial em relação a scanners tradicionais é o contexto de dados sensíveis: reconhece tipos de dados pessoais (PII) e os utiliza para priorizar achados e gerar um relatório de privacidade.

No fluxo, o Bearer executa três passos: (i) uma verificação bloqueante, com severidade *critical, high, medium* e *exit-code: 1*; (ii) um relatório HTML de segurança, gerado mesmo se o passo anterior falhar; e (iii) um relatório de privacidade em CSV, que constitui o inventário dos dados pessoais manipulados pelo código. Os dois últimos passos usam *exit-code: 0* e servem como evidência, não como bloqueio. A severidade média é bloqueante porque o Bearer classifica vazamento de PII em logs (CWE-532) nesse nível, o que é crítico para um sistema sujeito à LGPD.

Como limitação, parte da documentação pública do Bearer classifica o suporte à linguagem Python como alfa. Os resultados devem, portanto, ser lidos como apoio à revisão humana, e não como garantia de cobertura total.

2.3 Trivy: inventário de componentes e SBOM

O Trivy, da Aqua Security, é um scanner de código aberto para imagens de contêiner, sistemas de arquivos e repositórios. Com a opção *--format cyclonedx*, ele gera um SBOM (*Software Bill of Materials*) no padrão CycloneDX; por padrão, esse formato representa o inventário e não inclui vulnerabilidades (AQUA SECURITY, [s.d.]).

No EmprestaCampus, o SBOM é gerado a partir da imagem Docker do backend (*python:3.14-slim* mais as dependências), e não apenas do arquivo *requirements.txt*. Assim, ele lista as versões efetivamente instaladas de Django, Django REST Framework e *cryptography*, além dos pacotes do sistema operacional da imagem. Um passo de resumo falha a tarefa se o SBOM sair vazio, e o arquivo é publicado como artefato *sbom-cyclonedx*, com retenção de 90 dias.

Cabe distinguir que esta tarefa produz inventário e não aplica, atualmente, bloqueio por vulnerabilidades conhecidas (CVE). Um SBOM documenta o que há na imagem, mas não prova que ela seja segura.

3 INTEGRAÇÃO COM OS REQUISITOS DO PROJETO

O EmprestaCampus declara, em seu README, foco em segurança da informação e conformidade com a Lei Geral de Proteção de Dados (LGPD), e manipula dados pessoais de usuários, registros de empréstimos e trilhas de auditoria. A esteira transforma esses requisitos em verificações repetíveis e auditáveis.

3.1 Validação de privacidade e a LGPD

A Lei n. 13.709/2018 exige, no art. 37, que controlador e operador mantenham registro das operações de tratamento de dados pessoais e, no art. 46, que adotem medidas de segurança, técnicas e administrativas, aptas a proteger os dados contra acessos não autorizados e situações acidentais ou ilícitas de destruição, perda, alteração ou comunicação (BRASIL, 2018). Nesse contexto:

a) o relatório de privacidade do Bearer (CSV) fornece o mapeamento de quais tipos de dados pessoais o código manipula e onde, servindo de insumo técnico para o registro de operações do art. 37 e regenerado a cada execução;
b) o bloqueio por severidade do Bearer impede que alterações que vazem PII (por exemplo, em logs) cheguem à ramificação principal, o que sustenta a medida preventiva do art. 46;
c) o ZAP verifica, em execução, falhas de injeção que poderiam expor a base de dados pessoais.

3.2 SBOM e a conformidade do produto entregue

O SBOM CycloneDX é um documento verificável que acompanha a versão entregue. Para clientes e partes interessadas, ele permite:

a) rastreabilidade, ao indicar exatamente quais bibliotecas e pacotes de sistema compõem a imagem;

b) resposta a vulnerabilidades, pois, quando um novo CVE for divulgado, consultar o SBOM indica se o componente afetado está presente, sem reconstruir a imagem;
c) prestação de contas, uma vez que o artefato fica associado à execução que o gerou, com retenção de 90 dias;
d) integridade da própria ferramenta, já que o binário do Trivy é verificado por SHA-256 contra o arquivo oficial de somas de verificação, reduzindo o risco de adulteração na cadeia de suprimentos.

3.3 Limites da esteira

Um fluxo aprovado significa que as verificações configuradas passaram, não que o sistema esteja livre de vulnerabilidades. Em particular, os achados WARN do ZAP não bloqueiam; o ZAP parte da raiz e da tela de login, de modo que rotas autenticadas podem ter cobertura limitada; a tarefa do Trivy não bloqueia por CVE; e a esteira ainda não executa a suíte de testes funcionais (*pytest*) mencionada no README. Além disso, para que uma tarefa reprovada impeça de fato a integração de um *pull request*, é necessário configurar regras de proteção da ramificação principal no GitHub, exigindo esses *checks*.

4 EVIDÊNCIAS DE FUNCIONAMENTO

Os dados desta seção foram lidos diretamente da página pública do GitHub Actions do repositório, em 4 de novembro de 2026. Os quadros reproduzem esses dados em texto e **não são capturas de tela**. Os espaços tracejados foram reservados para a inserção dos *prints* reais, obtidos no navegador, que complementam a evidência.

4.1 Execução com os três jobs bem-sucedidos

O Quadro 2 resume a execução número 3 do fluxo e o Quadro 3 detalha o resultado de cada tarefa.

Quadro 2 – Resumo da execução #3 do fluxo DevSecOps Avançado

Campo	**Valor observado**
Fluxo	DevSecOps Avançado, execução #3
Acionamento	Manual (*workflow_dispatch*), em 04/11/2026, às 22h34
Commit / ramificação	3ca09a2 / main
Status	**Success**
Duração total	3 min 41 s
Artefatos	3

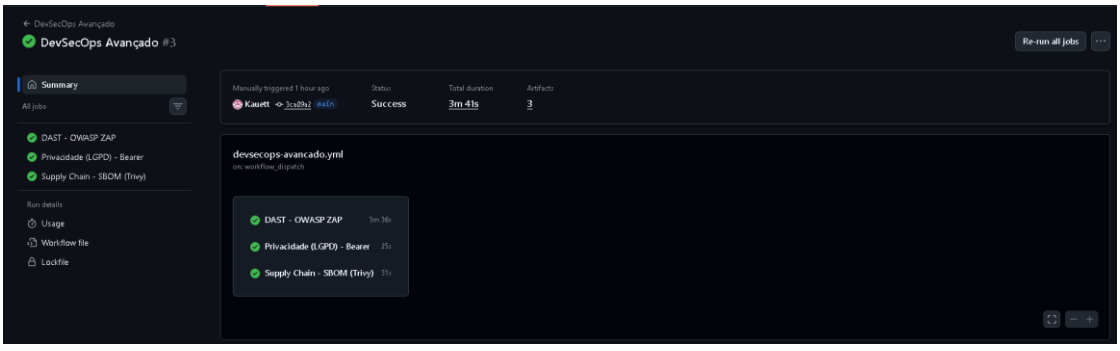
Fonte: GitHub Actions (EMPRESTACAMPUS, 2026).

Quadro 3 – Resultado de cada tarefa na execução #3

Tarefa	**Duração**	**Resultado**
DAST – OWASP ZAP	3 min 36 s	**Sucesso**
Privacidade (LGPD) – Bearer	25 s	**Sucesso**
Supply Chain – SBOM (Trivy)	31 s	**Sucesso**

Fonte: GitHub Actions (EMPRESTACAMPUS, 2026).

Figura 1 – Tela do GitHub Actions com as três tarefas concluídas com sucesso (a inserir)



Fonte: GitHub Actions (EMPRESTACAMPUS, 2026).

4.2 Artefato SBOM gerado e disponível para download

A seção *Artifacts* da execução #3 lista três artefatos publicados, incluindo o SBOM CycloneDX gerado pelo Trivy, conforme o Quadro 4. O download exige

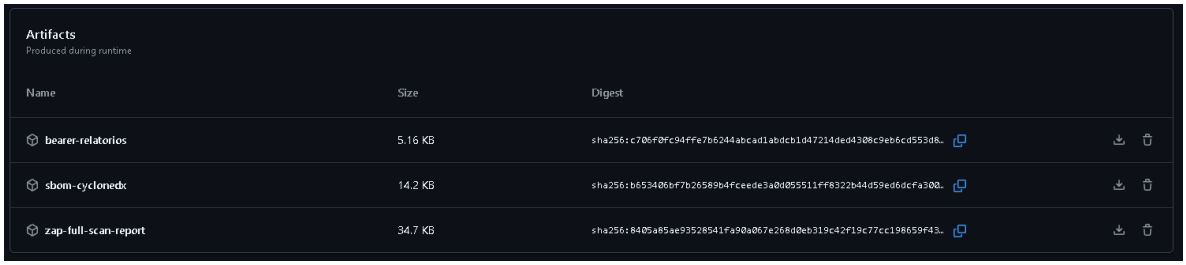
autenticação no GitHub, e o hash exibido permite verificar a integridade do arquivo baixado.

Quadro 4 – Artefatos publicados na execução #3

Artefato	Tamanho	Digest SHA-256
sbom-cyclonedx	14,2 KB	b653406bf7b26589b4fceede3a0d055511ff8322b44d59ed6dcfa3008078137a
zap-full-scan-report	34,7 KB	8405a85ae93528541fa90a067e268d0eb319c42f19c77cc198659f4354289a68
bearer-relatorios	5,16 KB	c706f0fc94ffe7b6244abcad1abdcb1d47214ded4308c9eb6cd553d8ebd774fd

Fonte: GitHub Actions (EMPRESTACAMPUS, 2026).

Figura 2 – Artefato SBOM disponível para download (a inserir)



Fonte: GitHub Actions (EMPRESTACAMPUS, 2026)

5 CONCLUSÃO

O EmprestaCampus dispõe de uma esteira DevSecOps funcional baseada em ferramentas gratuitas, com três vertentes complementares: DAST (ZAP), privacidade (Bearer) e SBOM (Trivy). A última execução verificada (#3) concluiu as três tarefas com sucesso e publicou os três artefatos esperados.

Recomenda-se, como próximos passos, exigir os *checks* na proteção da ramificação principal, adicionar uma tarefa de testes automatizados, ampliar a cobertura autenticada do ZAP e, se desejado, incluir bloqueio por CVE no Trivy.

REFERÊNCIAS

AQUA SECURITY. **CycloneDX generation**. [S. l.]: Aqua Security, [s.d.]. Disponível em: https://trivy.dev/v0.39/docs/sbom/cyclonedx. Acesso em: 4 nov. 2026.

BEARER. **Bearer CLI**: documentação. [S. l.]: Bearer, [s.d.]. Disponível em: https://docs.bearer.com/. Acesso em: 4 nov. 2026.

BRASIL. **Lei n. 13.709, de 14 de agosto de 2018**. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: http://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 4 nov. 2026.

EMPRESTACAMPUS. **DevSecOps Avançado**: execução #3. [S. l.]: GitHub Actions, 2026. Disponível em: https://github.com/carlosvbr/EmprestaCampus/actions/runs/41926487844. Acesso em: 4 nov. 2026.

ZAP. **ZAP Action Full Scan**. [S. l.]: ZAP, [s.d.]. Disponível em: https://github.com/zaproxy/action-full-scan. Acesso em: 4 nov. 2026.